

信息安全测评与 风险评估

编制完整测评方案

授课教师：张玉



目录

CONTENTS

- 01 复习回顾
- 02 任务导入（10分钟）
- 03 学习目标
- 04 教师示范——方案编制流程（15分钟）

- 复习回顾

复习目标

巩固上节课“测评方案结构学习”（2.1）的核心知识点



问题 1 一份完整的等保测评方案包含哪六个核心要素？

参考答案： 项目概述、测评依据、测评范围、测评方法、日程安排、人员分工

问题 2 测评对象选取应遵循哪些原则？

参考答案： 应测尽测原则、关键性原则、代表性原则、抽样原则（不低于30%）

问题 3 什么情况下可以对测评指标进行裁剪？

参考答案： 系统不涉及某项技术领域时（如无无线网络则不测“无线接入控制”），需说明不适用理由

- 任务导入（10分钟）

情景案例



小王接到三级系统等保测评任务，未认真编制方案，仅下载通用模板修改名称便带到现场。

结果：

- ① 架构不同，大量指标不适用；
- ② 未定对象，现场找指标耗时；
- ③ 范围不清，漏测与多测并存；
- ④ 客户质疑，项目延期满意度低。

? 问题讨论

- ① 案例中出现了哪些问题？
- ② 如何避免这些问题？
- ③ 好方案与差方案的差别在哪？

学习编制专业、规范的等保测评方案。

每位同学需完成一份完整方案。



- 学习目标

01

能够依据定级报告和系统架构，正确选取测评对象并说明理由

02

能够对照GB/T 22239标准，准确选取适用的测评指标

03

能够参照模板，独立编制一份完整的等保测评方案

04

培养严谨、细致、规范的职业工作习惯



- 方案编制流程



- 示范场景——XX市政务服务中心项目



综合管理平台

XX市政务服务中心

项目基本信息	详细说明
系统名称	XX市政务服务中心综合管理平台
安全保护等级	第三级（S3A3）
主管部门	XX市政务服务管理局
建设单位	XX市大数据发展局
系统功能	统一政务服务门户、事项管理、预约排号、排队叫号、综合评价、数据统计
用户规模	约200个窗口、日均接待群众约5000人次
数据敏感性	含公民身份信息、联系方式、办事记录等个人敏感信息
关键业务	在线预约、窗口叫号、评价管理、数据上报

- 第一阶段——解读定级报告

解读步骤

步骤	操作内容	关键信息提取
1	阅读定级报告封面	系统名称、定级结论、定级日期
2	查看定级依据	依据GB/T22240标准，采用何种定级方法
3	确认安全等级	业务信息安全等级（S）+系统服务安全等级（A）
4	了解系统描述	系统功能、网络结构、数据流程、业务范围
5	记录关键信息	主管部门、建设单位、运维单位、联系人信息

定级报告解读要点

三级系统意味着什么？

测评指标更多、要求更严格、测评周期更短（每年一次）

S3A3的含义？

业务信息安全等级为3级，系统服务安全等级为3级

- 第二阶段——分析系统架构

分析维度	分析内容	记录要求
网络拓扑	网络是如何分区的？边界在哪里？	绘制或确认拓扑图
设备清单	有哪些网络设备、安全设备、服务器？	记录型号、数量、IP段
业务应用	运行了哪些业务系统？面向什么用户？	记录应用名称、功能
数据流	数据从哪里来、到哪里去？	标注核心数据流向
管理方式	系统如何管理？是否有远程管理？	记录管理方式



实操技巧 1

如果客户没有提供现成的架构图，可以通过访谈和现场勘察绘制



实操技巧 2

设备清单是后续**选取测评对象**的核心依据

— 第三阶段——确定测评范围

测评范围维度	本次覆盖内容	说明
物理位置	XX市政务服务中心数据中心机房（主楼5楼）	核心机房
网络区域	互联网边界区、核心交换区、服务器区、管理区	四个关键区域
系统边界	从互联网入口到数据库的全链路	涵盖所有关键节点
业务范围	政务服务门户、事项管理、预约排号、叫号、评价、统计	6个功能模块



“应测尽测”

所有承载核心业务的设备和系统都应
纳入范围



“边界清晰”

明确哪些在范围内、哪些在范围外，
避免争议



“合理裁剪”

对不涉及的技术领域可以裁剪，但须
说明理由

- 第四阶段——选取测评对象

序号	设备/系统名称	型号/规格	数量	是否测评	选取理由
1	边界防火墙	华为USG6000	1台	√	边界防护核心设备，三级必须测
2	核心交换机	华为S12708	2台（堆叠）	√	网络核心，承载所有业务流量
3	Web服务器	华为RH2288（Linux）	3台	√（抽2台）	同质化设备，抽样30%以上
4	应用服务器	华为RH2288（Linux）	2台	√	业务核心，全部测评
5	数据库服务器	华为RH2288（Windows）	2台	√（抽1台）	同质化设备，抽样50%
6	堡垒机	齐治	1台	√	运维管理核心，三级必须测
7	日志审计系统	天融信	1台	√	安全审计核心，三级要求
8	WAF	安恒	1台	√	Web安全防护，必须测
9	办公终端	联想	50台	×	非核心设备，不纳入测评范围
10	打印机	惠普	10台	×	非信息系统设备，不纳入抽样

i 说明：Web服务器3台抽2台（**66%**），数据库服务器2台抽1台（**50%**），均超过**30%**的抽样比例要求。

- 第五阶段——确定测评指标（以“安全计算环境”为例）

序号	测评指标大类	三级要求指标项数	适用项数	不适用项数	不适用理由
1	身份鉴别	4项	4项	0项	—
2	访问控制	7项	7项	0项	—
3	安全审计	4项	4项	0项	—
4	入侵防范	6项	6项	0项	—
5	恶意代码防范	1项	1项	0项	—
6	可信验证	1项	0项	1项	系统未部署可信计算模块，暂不适用
7	数据完整性	2项	2项	0项	—
8	数据保密性	2项	2项	0项	—
9	数据备份恢复	3项	3项	0项	—
10	剩余信息保护	2项	2项	0项	—
11	个人信息保护	2项	2项	0项	—
合计		34项	33项	1项	可信验证项暂不适用

- 方案结构——完整内容框架

章节	标题	核心内容
封面	——	项目名称、委托单位、测评机构、编制日期、版本号
目录	——	自动生成，页码标注
第1章	项目概述	项目背景、目的意义、系统描述、安全等级
第2章	测评依据	列明全部依据（标准、法规、文件）
第3章	测评范围	物理范围、网络范围、业务范围
第4章	测评对象	设备清单、选取理由、抽样说明
第5章	测评指标	指标清单、适用性分析、不适用理由
第6章	测评方法	访谈、核查、测试方法说明
第7章	日程安排	每日工作计划、时间节点
第8章	人员分工	项目组成员及职责
第9章	风险控制	实施风险及应对措施
附件	——	参考文献、补充说明

- 测评方案模板（封面）

章节	标题
封面	---
目录	---
第1章	项目概述
第2章	测评依据
第3章	测评范围
第4章	测评对象
第5章	测评指标
第6章	测评方法
第7章	日程安排
第8章	人员分工
第9章	风险控制
附件	---

信息安全等级保护测评方案
(第三级 评估)

项目名称: XX市政务服务中心综合管理平台等保测评

委托单位: XX市政务服务管理局

测评机构: XX信息安全测评中心

编制日期: 2026年9月

版本号: V1.0

编制: _____ 审核: _____ 批准: _____

- 测评方案模板（第一章 项目概述）

章节	标题
封面	——
目录	——
第1章	项目概述
第2章	测评依据
第3章	测评范围
第4章	测评对象
第5章	测评指标
第6章	测评方法
第7章	日程安排
第8章	人员分工
第9章	风险控制
附件	——

项目背景

XX市政务服务中心综合管理平台是XX市政务服务“一网通办”的核心支撑系统，承载全市200个政务服务窗口的日常业务，日均服务群众约5000人次。为落实《网络安全法》及等级保护制度要求，确保系统安全稳定运行，特委托XX信息安全测评中心对该系统进行第三等级保护测评。

测评目的

1. 全面检查系统安全保护措施与国家等级保护标准的符合性；
2. 发现系统存在的安全隐患和薄弱环节；
3. 提出针对性的安全整改建议；
4. 为系统安全运行提供保障依据。

系统描述

系统名称	XX市政务服务中心综合管理平台
安全保护等级	第三级（S3A3）
主管部门	XX市政务服务管理局
建设单位	XX市大数据发展局
系统功能	统一政务服务门户、事项管理、预约排号、排队叫号、综合评价、数据统计
用户规模	约200个窗口、日均服务约5000人次
数据敏感性	含公民身份信息、联系方式、办事记录等个人敏感信息

- 测评方案模板（第二章 测评依据）

章节	标题
封面	——
目录	——
第1章	项目概述
第2章	测评依据
第3章	测评范围
第4章	测评对象
第5章	测评指标
第6章	测评方法
第7章	日程安排
第8章	人员分工
第9章	风险控制
附件	——



2.1 法律法规

- (1) 《中华人民共和国网络安全法》
- (2) 《中华人民共和国数据安全法》
- (3) 《中华人民共和国个人信息保护法》



2.2 国家标准

- (1) GB/T 22239-2019 《信息安全技术 网络安全等级保护基本要求》
- (2) GB/T 28448-2019 《信息安全技术 网络安全等级保护测评要求》
- (3) GB/T 28449-2018 《信息安全技术 网络安全等级保护测评过程指南》



2.3 其他文件

- (1) 《XX市政务服务中心综合管理平台定级报告》
- (2) 《XX市政务服务中心综合管理平台系统设计方案》
- (3) 客户提供的其他技术文档和管理文档

- 测评方案模板（第三章 测评范围）

3.1 物理范围

本次测评覆盖XX市政务服务中心数据中心机房（主楼5楼），面积约200平方米，包含服务器机柜、网络机柜、安全设备机柜、配电柜等。

3.2 网络范围

本次测评覆盖以下网络区域：

- （1）互联网边界区：从互联网出口至边界防火墙，含边界防火墙设备；
- （2）核心交换区：核心交换机及核心网络链路；
- （3）服务器区：Web服务器、应用服务器、数据库服务器所在的服务器网络区域；
- （4）管理区：堡垒机、日志审计系统所在的管理区域。

3.3 业务范围

本次测评覆盖以下6个业务功能模块：

- | | |
|-------------|-------------|
| （1）统一政务服务门户 | （2）事项管理系统 |
| （3）预约排号系统 | （4）排队叫号系统 |
| （5）综合评价系统 | （6）数据统计分析系统 |

- 测评方案模板（第四章 测评对象）

4.1 测评对象清单

序号	设备/系统名称	型号/规格	数量	是否测评	抽样说明
1	边界防火墙	华为USG6000	1台	是	100%测评
2	核心交换机	华为S12708	2台	是	100%测评（堆叠）
3	Web服务器	华为RH2288（Linux）	3台	是	抽2台（66%）
4	应用服务器	华为RH2288（Linux）	2台	是	100%测评
5	数据库服务器	华为RH2288（Win）	2台	是	抽1台（50%）
6	堡垒机	齐治	1台	是	100%测评
7	日志审计系统	天融信	1台	是	100%测评
8	WAF	安恒	1台	是	100%测评

4.2 抽样理由说明

- （1）Web服务器3台配置一致、部署相同应用，按照抽样原则抽取2台（66%），超过30%的抽样比例要求；
- （2）数据库服务器2台配置一致，抽取1台（50%），满足抽样要求。

- 测评方案模板（第五章 测评指标 上）

5.1 安全物理环境
(共10个子类，全部适用)

序号	子类名称	三级要求项数	适用项数	不适用理由
1	物理位置选择	2项	2项	——
2	物理访问控制	1项	1项	——
3	防盗窃和防破坏	3项	3项	——
4	防雷击	2项	2项	——
5	防火	3项	3项	——
6	防水和防潮	3项	3项	——
7	防静电	2项	2项	——
8	温湿度控制	1项	1项	——
9	电力供应	3项	3项	——
10	电磁防护	2项	2项	——

5.2 安全通信网络（共3个子类，全部适用）

序号	子类名称	三级要求项数	适用项数	不适用理由
1	网络架构	5项	5项	——
2	通信传输	2项	2项	——
3	可信验证	1项	0项	未部署可信计算模块

- 测评方案模板（第五章 测评指标 下）

5.3 安全区域边界（共6个子类，全部适用）

序号	子类名称	三级要求项数	适用项数	不适用理由
1	边界防护	4项	4项	
2	访问控制	5项	5项	
3	入侵防范	4项	4项	
4	恶意代码和垃圾邮件防范	2项	2项	
5	安全审计	4项	4项	
6	可信验证	1项	0项	未部署可信计算模块

5.4 安全计算环境（1项不适用）

序号	子类名称	三级要求项数	适用项数	不适用理由
1	身份鉴别	4项	4项	
2	访问控制	7项	7项	
3	安全审计	4项	4项	
4	入侵防范	6项	6项	
5	恶意代码防范	1项	1项	
6	**可信验证**	1项	**0项**	未部署可信计算模块
7	数据完整性	2项	2项	
8	数据保密性	2项	2项	
9	数据备份恢复	3项	3项	
10	剩余信息保护	2项	2项	
11	个人信息保护	2项	2项	

5.5 安全管理中心共4个子类，全部适用

5.6 安全管理制度共4个子类，全部适用

5.7 安全管理机构共5个子类，全部适用

5.8 安全管理人员共4个子类，全部适用

5.9 安全建设管理共10个子类，全部适用

5.10 安全运维管理共14个子类，全部适用

- 测评方案模板（第六章 测评方法）

第6章 测评方法：本次测评采用以下三种方法

6.1

访谈法

对系统管理人员、运维人员、安全负责人等进行面对面访谈，了解安全管理制度的执行情况、安全措施落实情况。

访谈对象：

- 系统管理员（2人）
- 安全管理员（1人）
- 数据库管理员（1人）
- 网络管理员（1人）

6.2

核查法

(1) 上机核查：登录网络设备、安全设备、主机、数据库，查看配置参数，对照标准进行符合性判断；

(2) 文档查阅：查阅安全管理制度文件、运维记录、备份记录等文档资料；

(3) 现场观察：实地查看机房物理环境、设备标识、线缆布设等。

6.3

测试法

(1) 漏洞扫描：使用Nessus/OpenVAS对目标系统进行漏洞扫描；

(2) 配置核查：使用配置核查工具对主机、数据库进行基线核查；

(3) 功能验证：对应用系统身份鉴别、访问控制等功能进行人工验证。

- 测评方案模板（第七章 日程安排）

第1天（周一）

09:00-10:00 全员

项目启动会、签保密协议

10:00-12:00 A组

物理环境核查、安全管理文档查阅

14:00-17:00 B组

人员访谈（管理类）

第2天（周二）

09:00-12:00 A组

网络设备配置核查
（路由器、交换机）

14:00-17:00 A组

安全设备核查（防火墙、WAF）

第3天（周三）

09:00-12:00 A组

主机安全基线核查
（Linux）

14:00-17:00 A组

主机安全基线核查
（Windows）

第4天（周四）

09:00-12:00 A组

数据库安全配置核查
（MySQL）

14:00-17:00 A组

应用系统安全功能验证

第5天（周五）

09:00-12:00 A组

漏洞扫描与结果分析

14:00-15:00 全员

补充核查

15:00-16:00 全员

项目总结会

16:00-17:00 全员

撤离现场

- 第8章 人员分工



- 测评方案模板（第九章 风险控制）

9.1 可能的风险

01

业务中断风险

测评过程中可能影响系统正常运行



- 所有测评操作均在业务低峰期进行
- 涉及配置变更的操作，提前备份配置
- 漏洞扫描前与客户确认，避免对业务造成影响

02

数据泄露风险

测评过程中接触敏感数据



- 全体项目人员签署保密协议
- 测评数据严格管理，不携带客户数据离场
- 报告脱敏处理，不包含原始敏感数据

03

设备故障风险

设备操作不当可能导致配置丢失



- 操作前进行配置备份
- 操作过程中保留操作日志
- 紧急情况下可进行配置恢复

04

进度延误风险

客户配合不力或技术问题导致延期



- 提前与客户确认时间安排
- 每日汇总进度，及时调整
- 设置缓冲时间应对突发情况

- 小结与课后作业

01 本节核心要点

- ①方案编制的“六步法”——解读定级→分析架构→确定范围→选取对象→确定指标→编制方案
- ②测评对象选取的四大原则
- ③测评指标选取的适用性判断
- ④方案结构的9个章节

03 课后作业

- ①依据“XX市教育局管理平台”数据，编制等保测评方案
- ②提交至学习通平台
- ③预习“安全物理环境与通信网络测评”内容

02 质量自检清单

- | | |
|--|--|
| ☒ 封面信息完整 | ☒ 项目概述清晰 |
| ☒ 依据列明标准 | ☒ 测评范围明确 |
| ☒ 对象清单完整 | ☒ 指标清单完整 |
| ☒ 方法描述具体 | ☒ 日程安排合理 |
| ☒ 人员分工明确 | ☒ 格式规范通顺 |

思政小结

方案是测评工作的“施工蓝图”。方案的严谨性决定了测评的质量，规范性体现了机构专业水平。希望同学们以工匠精神对待每一份方案，以责任意识对待每一项测评。